

CS 546

Computer System Security

Lecture 5.2: Authentication

Instructor: Aarushi Goel

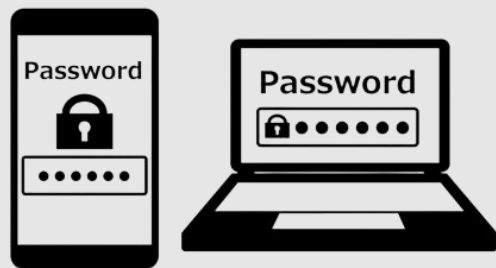
Fall 2026

User Identification and Authentication

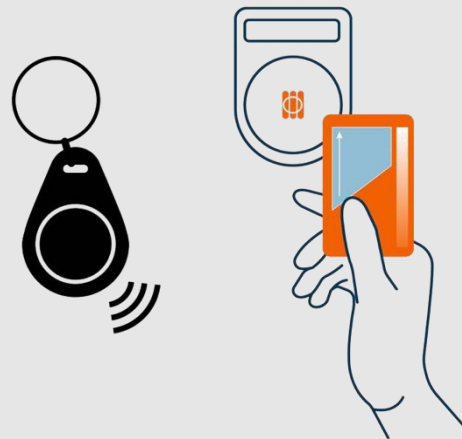
- **Identification:** asserting who a person is
- **Authentication:** proving that a user is who they claim they are

Authentication Mechanisms

Something the user knows



Something the user has

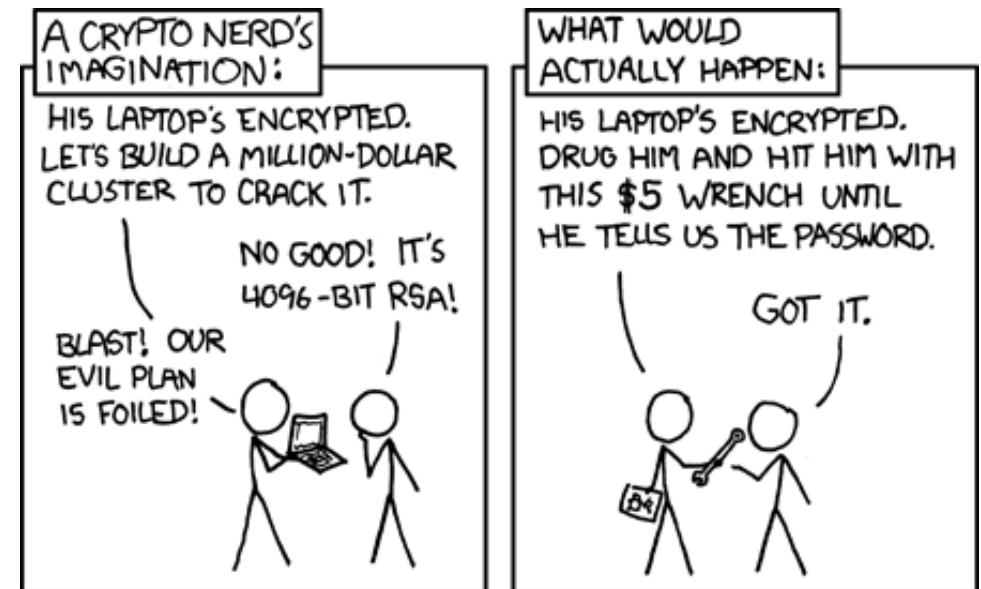


Something the user is



Something the User **Knows**

- The user has to know some secret to be authenticated
 - password, personal identification number (PIN), personal information like home address, date of birth, name of spouse (“security” questions)
- Suppose that a user provides her login name and password.
 - Does this imply user **identification**?
 - **No!**
 - What if an unauthorized person stole the password?
 - A password does not authenticate a person.
 - Successful authentication only implies that the user knew a particular secret. There is no way of telling the difference between the legitimate user and an intruder who has obtained that user’s password.
 - We will discuss identification later.



Problems with Passwords

- While it is the most widely deployed authentication mechanism, there are many problems with passwords/PINs/Security questions, etc. This is primarily because, there are **many attack vectors**:
 1. user's brain
 2. communication channel
 3. authentication server
- Problems:
 - **password guessing**: predicting weak passwords
 - **phishing & spoofing**: deceiving users to reveal their password
 - **leaked password files**: stealing user credentials

Password Guessing

(Low entropy passwords)

The Most Popular Passwords for Each Generation

THE READER'S DIGEST VERSION

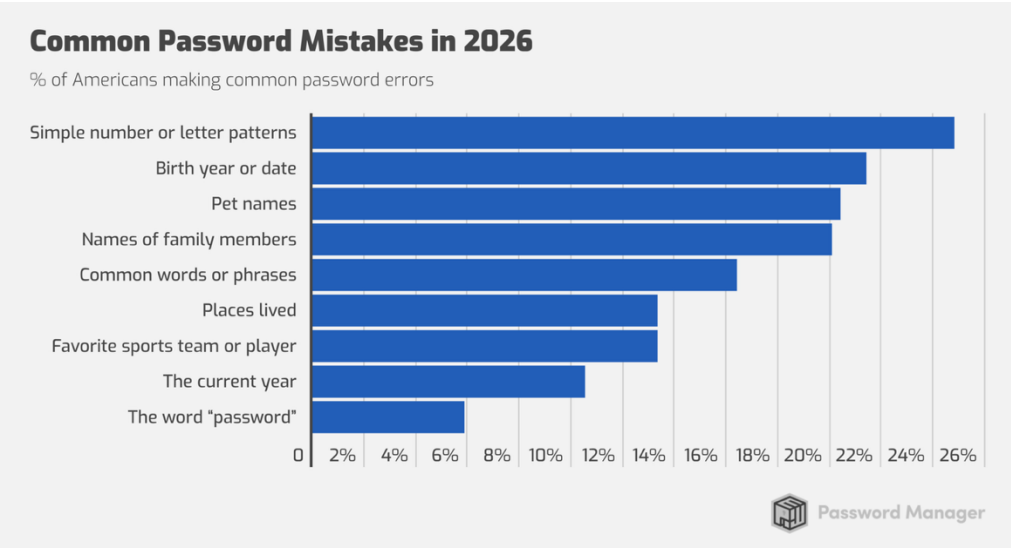
GEN Z		MILLENNIALS	
1	12345	1	123456
2	123456	2	1234qwer
3	12345678	3	123456789
4	123456789	4	12345678
5	password	5	12345

GEN X		BABY BOOMERS	
1	123456	1	123456
2	123456789	2	123456789
3	12345	3	12345
4	veronica	4	maria
5	lorena	5	Contraseña



Source: NordPass

RD



Time it takes a hacker to crack your password

2026

Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols
4	Instantly	Instantly	Instantly	Instantly	Instantly
5	Instantly	Instantly	46 mins	2 hours	3 hours
6	Instantly	37 mins	2 days	5 days	1 week
7	Instantly	16 hours	3 months	10 months	2 years
8	Instantly	2 weeks	12 years	50 years	132 years
9	2 hours	1 year	636 years	3k years	9k years
10	20 hours	32 years	33k years	191k years	645k years
11	1 week	839 years	1m years	11m years	45m years
12	3 months	21k years	89m years	737m years	3bn years
13	2 years	567k years	4bn years	45bn years	221bn years
14	23 years	14m years	241bn years	2tn years	15tn years
15	229 years	383m years	12tn years	175tn years	1qd years
16	2k years	9bn years	653tn years	10qd years	75qd years
17	22k years	259bn years	33qd years	675qd years	5qn years
18	228k years	6tn years	1qn years	41qn years	372qn years



Hive Systems

Read more and download at hivesystems.com/password

Password Guessing

(Passwords Re-use)

Two in Three Americans Still Reuse Passwords Across Accounts

Security.org reports that more than

two in three Americans reuse passwords across multiple accounts.

Password reuse means that when a credential is compromised on one service, the same password may put other accounts at risk—giving attackers more opportunities to turn a single exposure into broader account access.

57% Recycle Old Passwords When Creating New Ones

Security.org's also found that **57% of respondents** update passwords by modifying old ones and substituting characters. Small changes may create the appearance of a new password without eliminating the underlying risks associated with predictable, reused credentials.

Users Reused More Than Half of Their Passwords, Despite High Password Manager Adoption

A 2026 academic study of 437 students, faculty, and staff at a large U.S. university found that participants

reused more than half of their passwords, despite 94% reporting password manager use. Only 26% regularly used password managers to generate passwords. The findings show that password manager adoption alone does not guarantee that users will create unique credentials for every account.

Only 6% of 19 Billion Exposed Passwords Were Unique

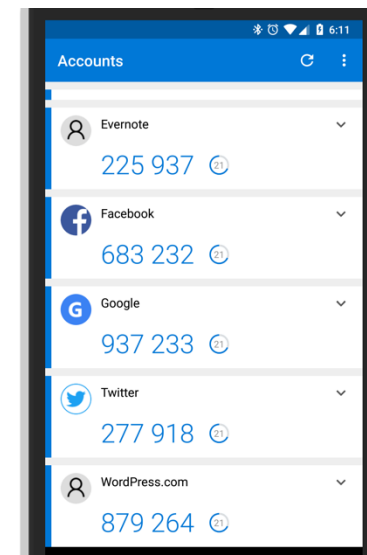
Cybernews researchers analyzed more than 19 billion passwords collected from data leaks, breaches, combolists, and infostealer logs and found that **only 6% were unique**. The findings show how frequently passwords are duplicated within exposed credential data, giving attackers a large pool of known passwords to use in credential-based attacks.

Password Guessing

(Countermeasures)

- **Password blacklists:** The system refuses to let users choose passwords that are known to be weak or commonly guessed, such as “password”, “123456”, or ones appearing in known breach lists.
- **Throttling (time, captcha):** The system does not necessarily stop login attempts but makes repeated attempts increasingly expensive. E.g., after several failures it may introduce a delay before the next attempt or require solving a CAPTCHA. The goal is to reduce the **rate of guesses**: an attacker who could otherwise try thousands of passwords per second may be limited to only a few attempts per minute.
- **Lockout after k attempts:** After k consecutive incorrect password attempts, the account is temporarily or permanently locked. This places a hard bound on how many guesses an attacker can make against a particular account.
- **Multi-factor Authentication (MFA):** The user must authenticate using two or more independent factors, so knowing the password alone is not sufficient to log in.

Your verification code is:
476080. Your code expires
in 10 minutes.



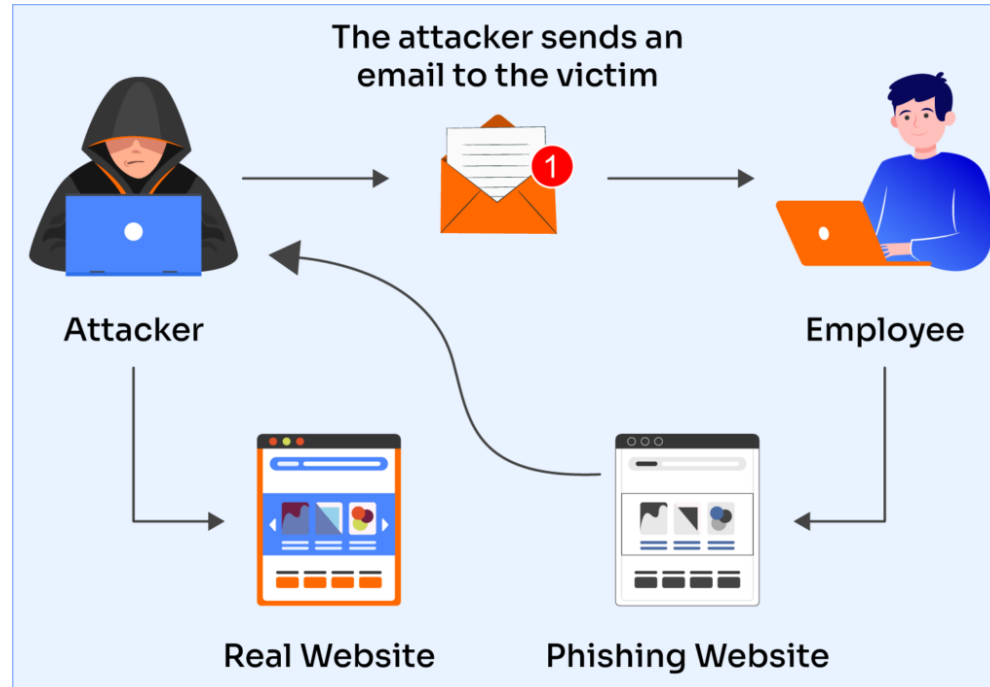
Phishing and Spoofing

- Authentication via passwords provide **unilateral authentication**.
- Computer verifies the user's identity, but the user has no guarantees about the identity of the party that has received the password.
- Phishing and spoofing are a type of **social engineering**.
- The users are deceived into sharing credentials or sensitive information (e.g., bank account number)
- Variations
 - Spear phishing: Personalized to you (like a mail merge)
 - Whaling: Targets the senior leaders of an organization

Phishing and Spoofing

(Examples of Phishing)

- Attacker impersonates the system to trick a user into releasing the password.
- Examples:
 - A message could claim to come from a service you are using
 - Tell you about an upgrade of the security procedures and ask you to enter your username and password at the new security site that will offer stronger protection



Phishing and Spoofing

(Example of Spoofing)

- Attacker starts a malicious program that presents a fake login screen and leaves the computer.
- If the next user coming to this machine enters username and password on the fake login screen, these values are captured by the malicious program.
 - login is then typically aborted with a (fake) error message and the spoofing program terminates
 - control returns to operating system, which now prompts the user with a genuine login request
 - thus, the victim does not suspect that something wrong has happened
 - the victim may think that the password was mistyped...

Phishing and Spoofing

(Prevention)

- **Training:** Teach users how phishing attacks work and what warning signs to look for.
 - ~~Look for the lock icon and https:~~ Phishing sites can easily obtain TLS certificates now.
 - Look for the real domain name: [micros0ft.com](#), [paypa1-login.com](#)
 - Never click links in email: “[Log in to your bank](#)”
 - Watch for weird email, bad grammar, etc: “[Your account will be deleted in 10 minutes—log in immediately](#)”
 - Fake phishing to test awareness
- **Email Provider Detection and Defenses:** Providers such as Gmail or Outlook can automatically analyze incoming mail for suspicious URLs, attachments, sender behavior, known malicious domains, and other indicators.
 - Sender Policy Framework (SPF): Did this message come from an authorized mail server?
 - Domain Keys Identified Mail (DKIM): Was this message cryptographically signed by the claimed domain and left intact?
 - Domain-based Message Authentication, Reporting, and Conformance (DMARC): Does that authentication align with the domain shown to the user, and what should I do if it does not?

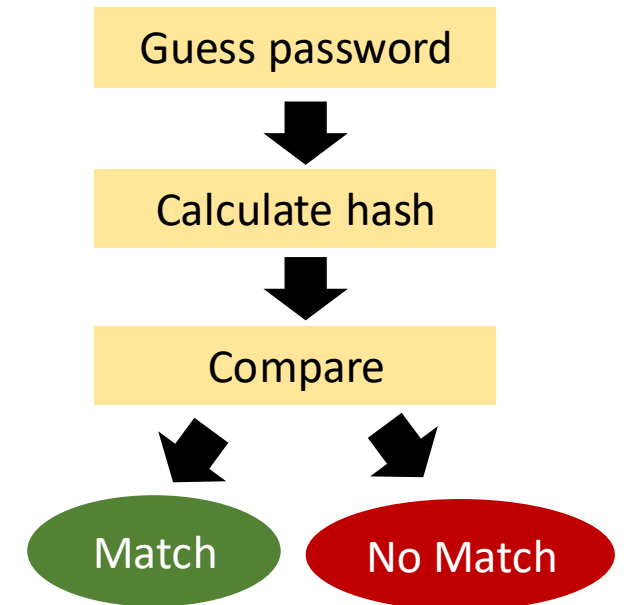
Leaked Password Files

- Breach authentication server to steal user credentials. Can be catastrophic if the passwords are stored in plaintext.
- Some famous examples:
 - **Facebook (2019 Internal Discovery)**: Facebook disclosed that it had inadvertently stored hundreds of millions of user passwords in plaintext
 - **Twitter / X (2018 Bug)**: Twitter admitted to a logging bug that wrote users' passwords to an internal log file in plaintext
 - **IEEE.org (2012)**: The Institute of Electrical and Electronics Engineers (IEEE) left an unencrypted FTP server open to the public for at least a month. A security researcher discovered that it contained 100,000 plaintext member passwords, which included the credentials of researchers at NASA, Stanford, Apple, and Google.
- Countermeasures:
 - Store only **password hashes**, never passwords in plaintext.
 - Protect the password-hash database using appropriate access controls and, where applicable, **encryption at rest**.

Leaked Password Files

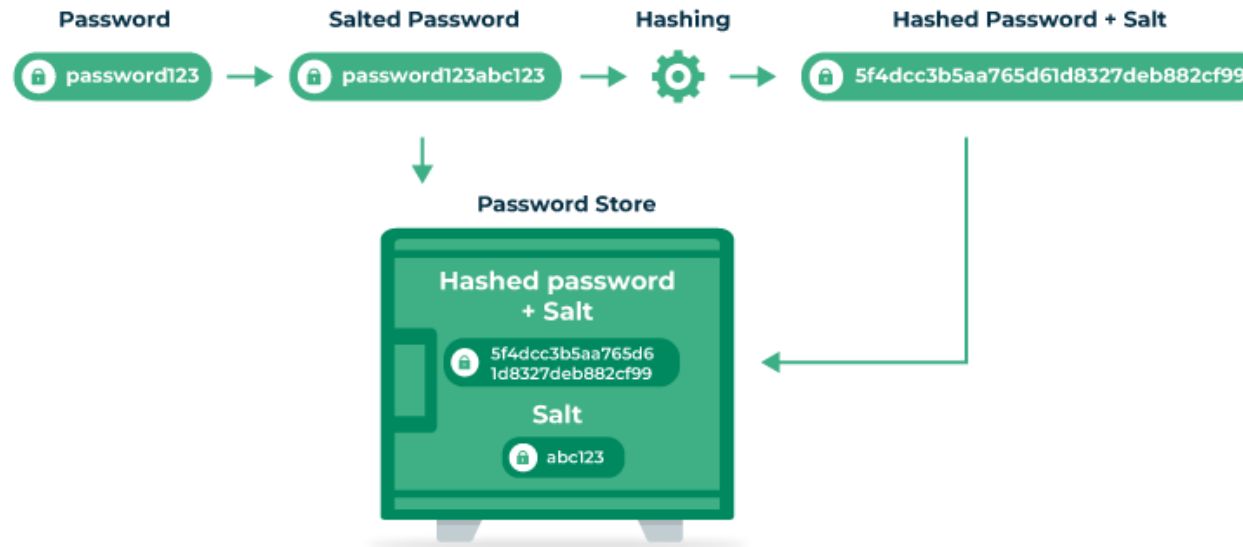
(Hashing Passwords is not enough)

- Suppose a server gets compromised and an attacker is able to obtain to decrypted password file that contains password hashes.
- The attacker can run offline dictionary attacks on leaked hashed passwords. Since most hashed passwords are weak passwords; this is quite effective.
- Preprocessing is often very useful in such attacks, e.g., precompute a dictionary-based set of password-hash pairs and use precomputed set for cracking any newly leaked hashed passwords.



Leaked Password Files

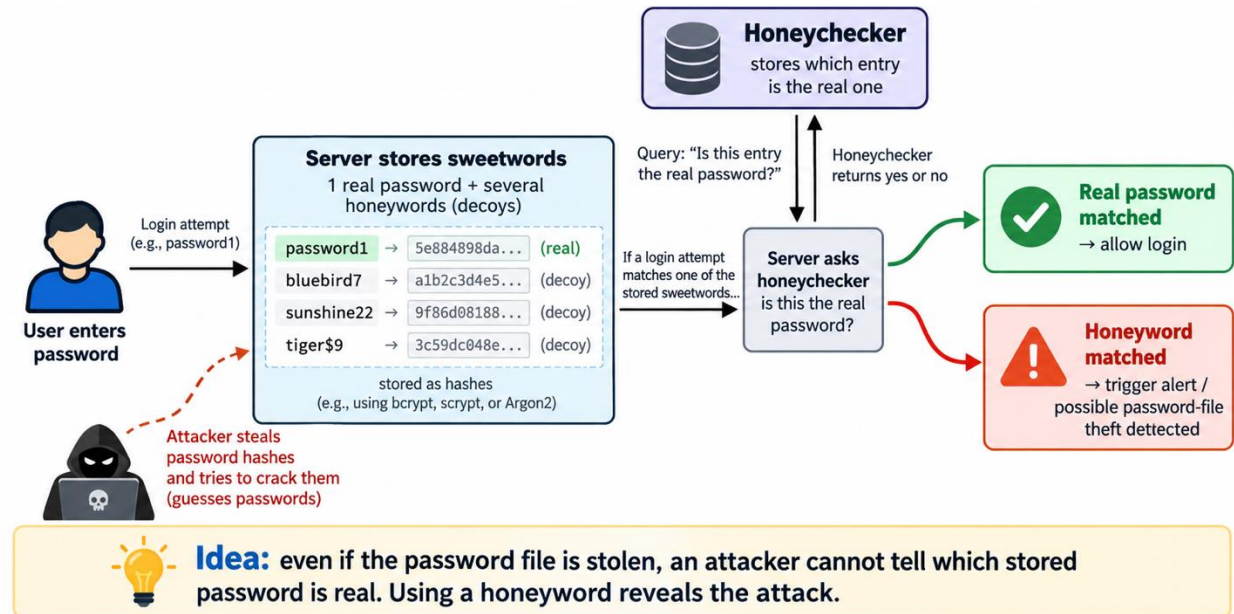
(Countermeasure - Salting)



- To slow down dictionary attacks, a user-specific salt is appended to a user's password before it is hashed.
- Each salt value is stored in the clear along with its corresponding hashed password.
- If two users have the same password, they will have different hashed passwords.
- Now preprocessing is useless; or it must be user specific!

Leaked Password Files (Other Countermeasures)

- **Hash strengthening:** to slow down dictionary attacks, a password is hashed k times before being stored.
- **Honeywords:** database includes multiple passwords per account
 - Only one is “real” and chosen by the user, others are fake and chosen by the server
 - Challenge: Make the honeywords look real but still be typo-safe (not so close as to provoke false alarms)
 - There is a Honeychecker that raises an alarm if a fake password is used. Honeychecker kept separate from password database.
 - Mostly a theoretical idea as of now.



Final Verdict on Passwords

- Despite these countermeasures, password breaches remain common.
- Users continue to exhibit **poor password habits**, including password reuse and choosing weak passwords.
- Although many modern breaches expose only password hashes, large numbers of passwords are also stolen directly in plaintext by **infostealer malware** running on users' devices. Such malware can extract passwords saved in browsers and applications, and the resulting credentials are often aggregated into massive ``combo lists'' that are sold or leaked online.
 - **184 Million Credential Dump (2025)**: Security researchers discovered an unprotected database containing roughly 184 million plaintext credentials associated with services including Apple, Google, Microsoft, and Instagram. The credentials were reportedly harvested from users' devices, illustrating how plaintext passwords can leak even when service providers themselves store passwords securely.
 - **RockYou2021**: A widely circulated compilation containing approximately 8.4 billion password entries in a single plaintext file. Rather than representing a breach of one organization, it aggregated passwords collected from previous leaks and cracked password hashes, creating a massive dictionary for password-guessing attacks.
- **Why aren't passwords dead?** Passwords remain by far the most widely deployable authentication mechanism: they require no specialized hardware, work across essentially all platforms, and are often more convenient and familiar to users than alternative authentication mechanisms.

Something the User **Has**

- User presents a physical token to be authenticated, e.g., keys, cards or identity tags (access to buildings), smart cards, etc.
- **Limitations:** physical tokens can be lost or stolen. Anybody in possession of token has the same rights as legitimate owner.
 - Similar to passwords, here **Authentication** $\nRightarrow$ **Identification**
- Physical tokens can also be used in combination with something you know. e.g., banks might ask for your photo ID and ask you to enter your PIN: a type of multi-factor authentication.

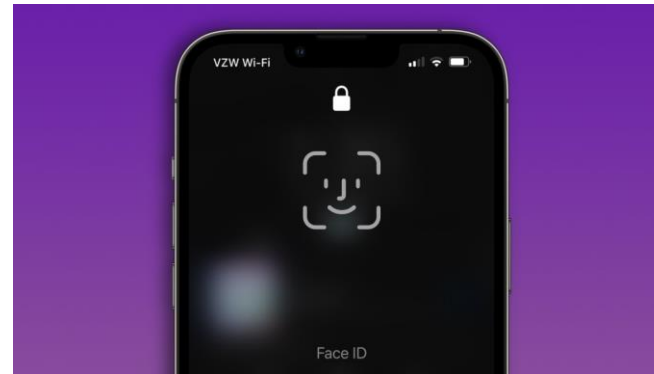


Something the User Is

- **Biometric schemes** use people's unique physical characteristics: face, fingerprints, iris patterns, hand geometry, etc.



- Biometrics seem to be the most secure solution for user authentication and are becoming increasingly common.



96 AT&T Wi-Fi 12:25 PM 98%
Cancel osxdaily.com

Set Up "Hey Siri"

This helps Siri recognize your voice when you say "Hey Siri."

[Set Up Now](#)



- Here **Authentication** $\Rightarrow$ **Identification**
- Problems with biometrics: Intrusive, expensive, sampling error, false readings, speed



Signal's Identification Mechanism

(Older Design)

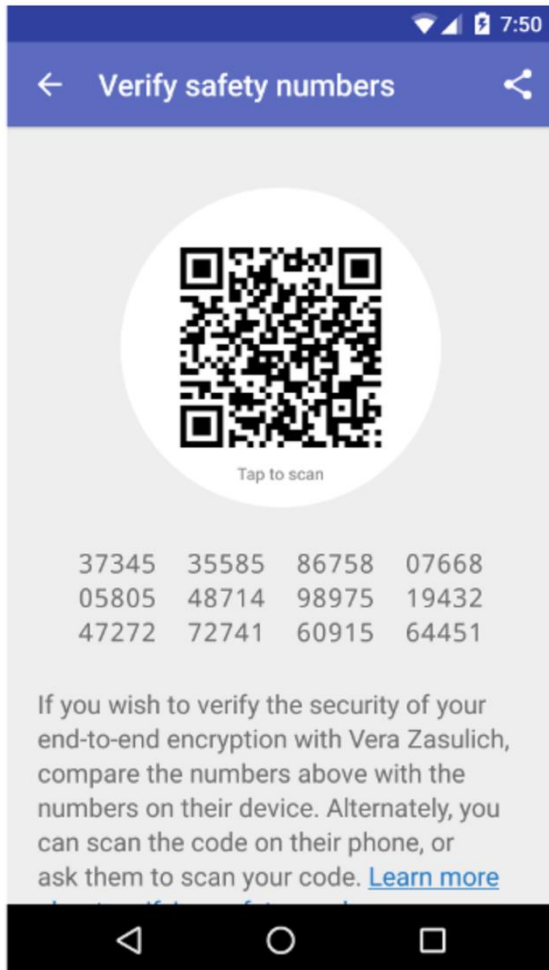


- Signal users could verify the privacy of their communication with a contact, by comparing their "fingerprint".
- Fingerprint here meant a hex encoded hash of a public key.
- Hexadecimal is an encoding that's familiar for people who work with software, but ends up leaving a lot of people out, primarily because hexadecimal isn't compatible with all alphabets.
- However, all supported languages have a representation for base-10 digits and hence, Signal decided to move to **safety numbers**.



Signal's Identification Mechanism

(New Design)



- Safety numbers allow Signal users to verify the privacy of their communication with a contact, either by comparing a number or by scanning a single QR code.
 - Numbers are visually and audibly distinct.
 - They reduce the size of the encoded value to make the comparison even easier. With the new encoding, users compare 12 groups of 5 digits with each other, which is half the size of what needed to be compared with the previous hexadecimal format.
-
- You can read about newer updates: <https://signal.org/blog/automatic-key-verification/>